

Use Security Reference Architectures to Industrialize Security-by-Design

William Dupre

© 2026 Gartner, Inc. and/or its affiliates. All rights reserved. Gartner is a registered trademark of Gartner, Inc. and its affiliates. This publication may not be reproduced or distributed in any form without Gartner's prior written permission. It consists of the opinions of Gartner's research organization, which should not be construed as statements of fact. While the information contained in this publication has been obtained from sources believed to be reliable, Gartner disclaims all warranties as to the accuracy, completeness or adequacy of such information. Although Gartner research may address legal and financial issues, Gartner does not provide legal or investment advice and its research should not be construed or used as such. Your access and use of this publication are governed by [Gartner's Usage Policy](#). Gartner prides itself on its reputation for independence and objectivity. Its research is produced independently by its research organization without input or influence from any third party. For further information, see ["Guiding Principles on Independence and Objectivity."](#)

Gartner®

Only 42% of security architects use strategy insights to help construct security capabilities.

n = 285 security and IT leaders, excluding not sure

Q03: Which best describes your organization's approach to technical security architecture?

Source: 2024 Gartner Future of Security Architecture Survey



**We need better ways
to bring rigor and
consistency to
our designs.**



Agenda

1. Security architecture — overview.
2. What is security by design?
3. Building security by design into architecting.
4. Assembling and curating reference architectures.

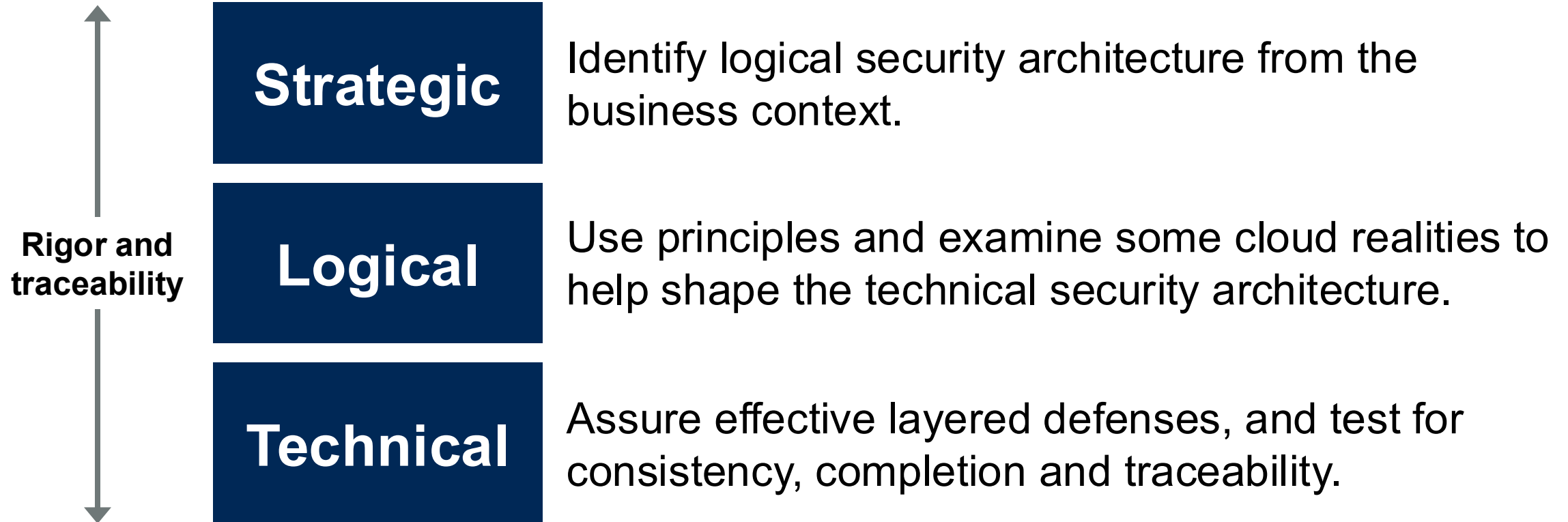
Agenda

1. Security architecture — overview.

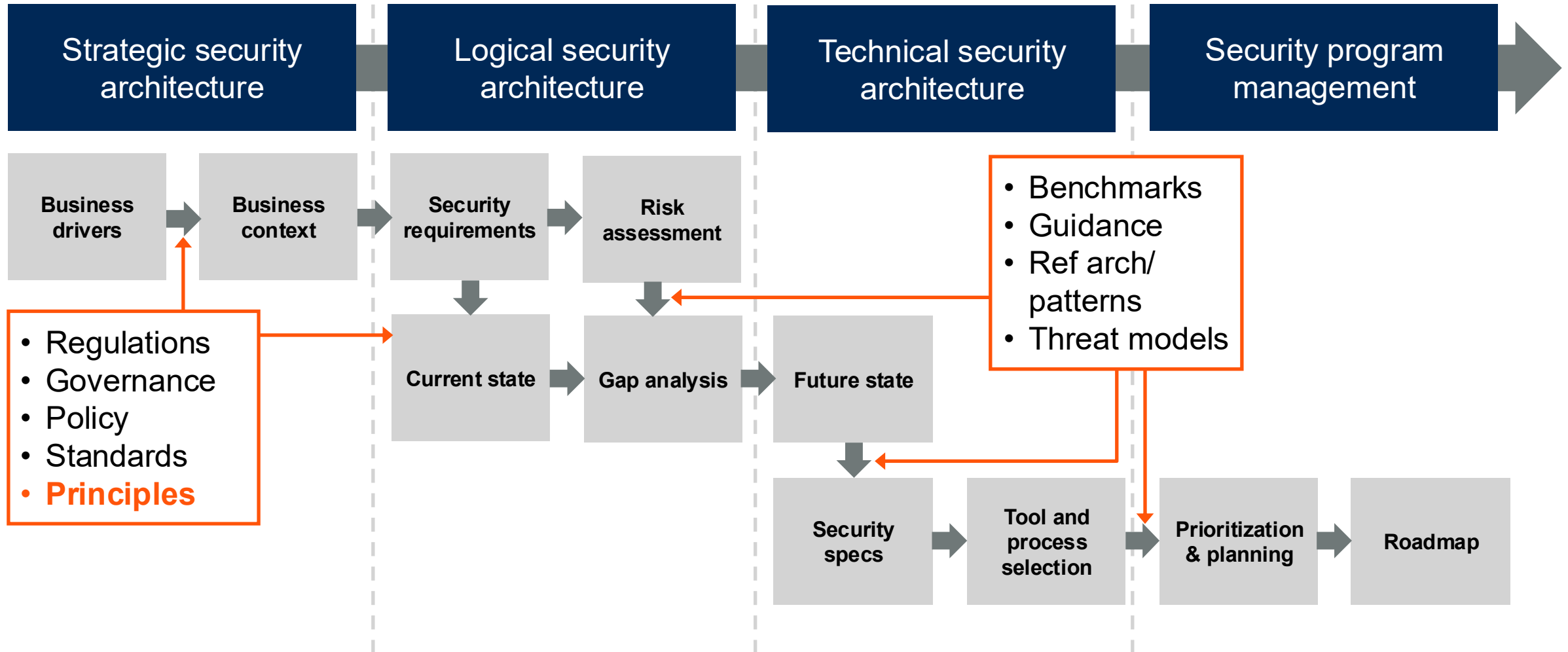
- 2. What is security by design?
- 3. Building security by design into architecting.
- 4. Assembling and curating reference architectures.



Architecting for Security



Architecting for Security



Why Use Security Architecture?

- 1 Business enabler**
- 2 Holistic approach**
- 3 Risk management**
- 4 Compliance**
- 5 Adaptability**
- 6 Cost effectiveness**

Agenda

1. Security architecture — overview.

2. What is security by design?

3. Building security by design into architecting.

4. Assembling and curating reference architectures.



What Is Security by Design?

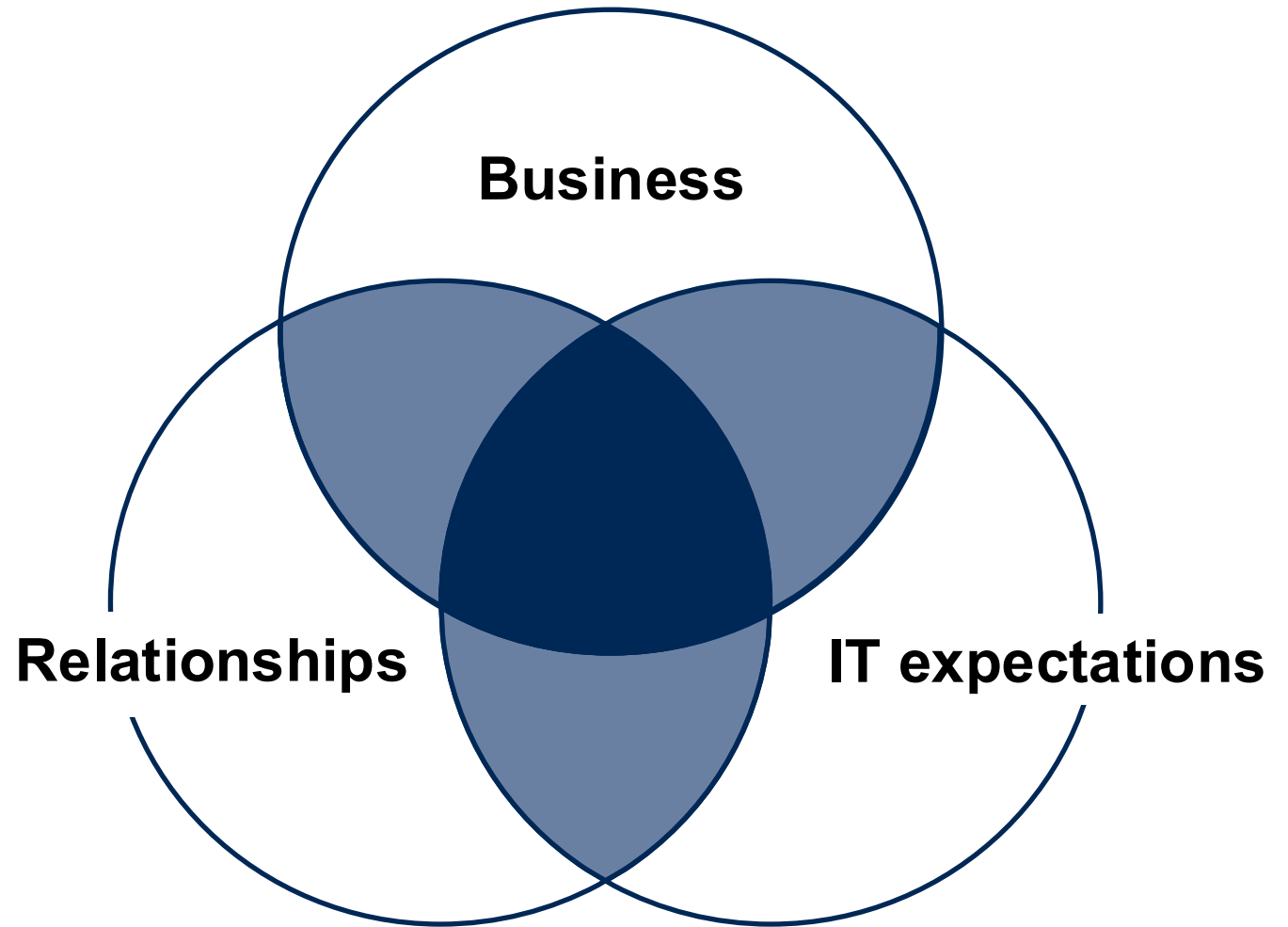
- Proactive security, not an afterthought
- Early identification of risk
- Holistic view of system security
- Continuous improvement for architecture design processes
- Business-focused



Collecting Security Drivers

Collect drivers as close to the source:

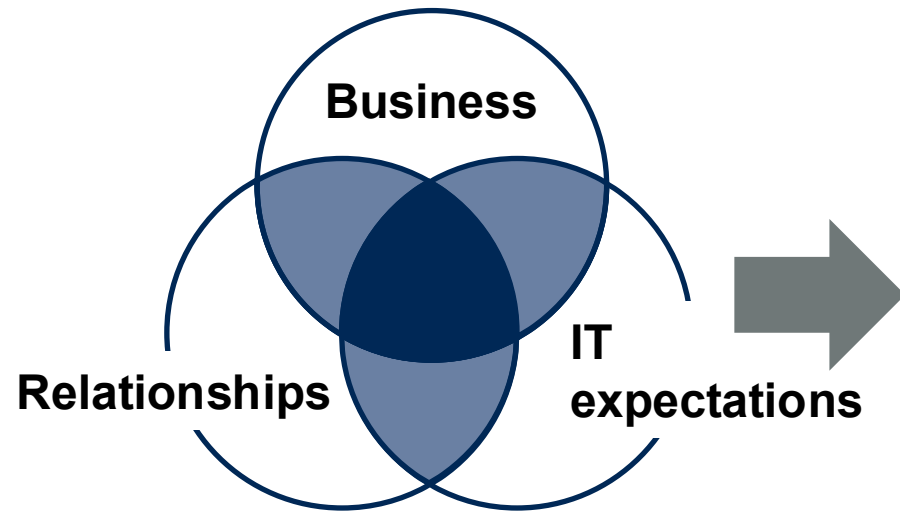
- C-suite/delegates
- Strategy statements
- Risk registers
- Project charters



Align Business Drivers With Industry Suggestions

Define a set of security-by-design principles that align with business objectives

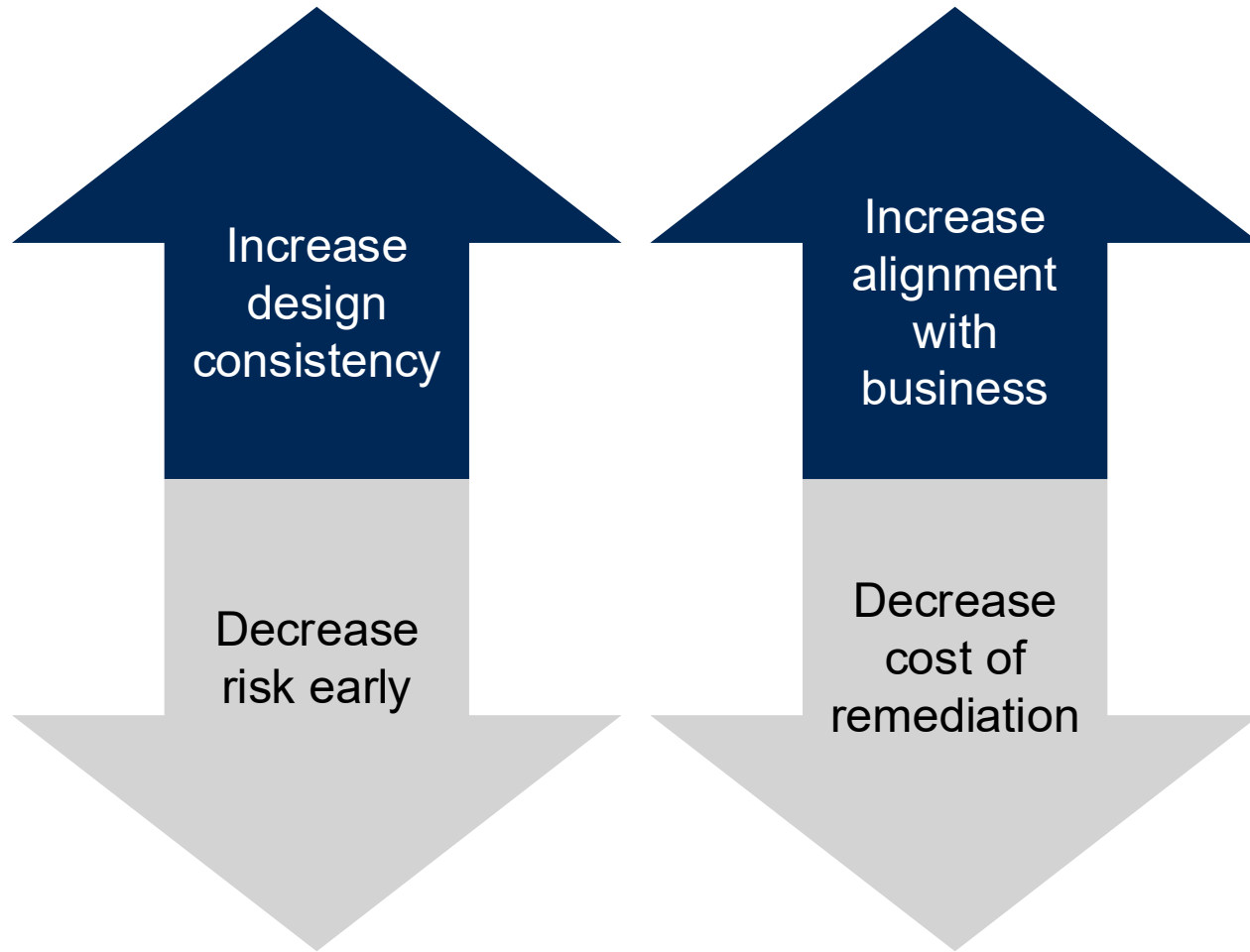
Examples:



Use sources of security-by-design thinking to help alignment

- Focus on user and identity
- Enforce least privilege
- Visibility and traceability
- Defense in depth
- Enforce security by default
- Minimize attack opportunity
- Implement zero trust
- Design into, not onto
- Make security an enabling function
- Secure after failure
- Ensure separation of duties
- Avoid security by obscurity
- Ensure defects are addressed
- Control applications rigorously
- Have redundant controls
- Implement zoning and domain separation
- Pursue modularity and composability
- Enforce least functionality

Security-by-Design Principles



It is cheaper to plan security into an IT project at its inception than it is to retrofit.

Designing security into IT projects ensures risks are addressed.

Security-by-Design Initiatives



[U.S. Department of Homeland Security's CISA](#) led effort with multiple nations' cybersecurity agencies.



[UK NCSC](#) has developed activities to follow to adopt security by design.



[Open Worldwide Application Security Project \(OWASP\)](#) has a cheat sheet on secure product design.

... If You Don't Implement Security by Design

- Increased chance of reputation risks.
- Less control over governance risks.
- Increased operational risk.
- Potential for legal risks.
- Increased financial risks.
- Lack of awareness of residual risks.



Proximity Alert — Secure by Design and Secure by Default



Secure by design is an application security alignment applied to product pipeline. The software product itself is “secure by design”.



Secure by default is when security is designed into software with minimal manual setup or configuration required by the consumer.

Agenda

1. Security architecture — overview.
2. What is security by design?
- 3. Building security by design into architecting.**
4. Assembling and curating reference architectures.



How Do You Implement Security by Design?

Prepare the organization and develop security-by-design culture

1

Apply stakeholder management; develop a communications plan.

2

Develop a security-by-design policy.

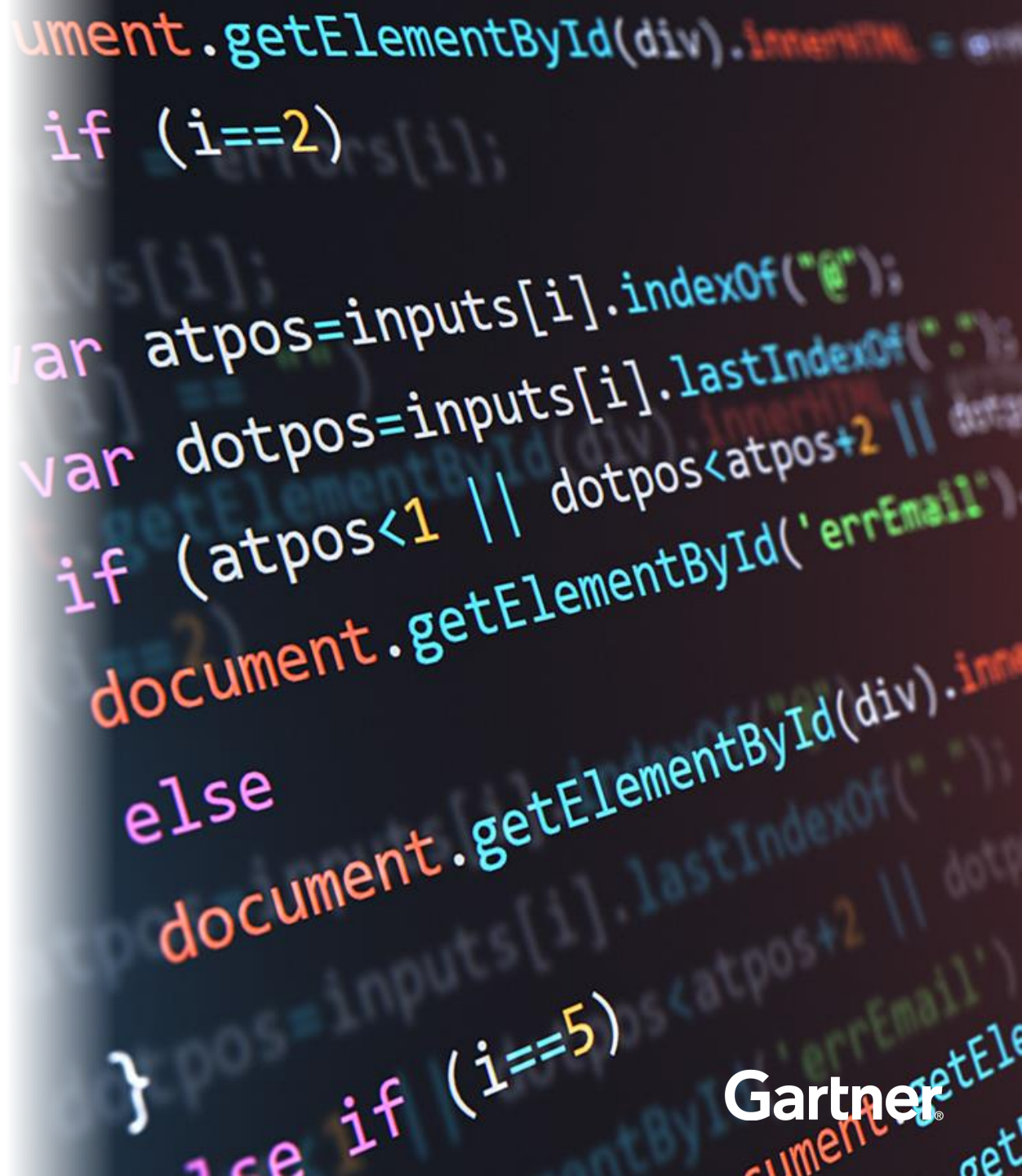
3

Identify and educate security-by-design champions.

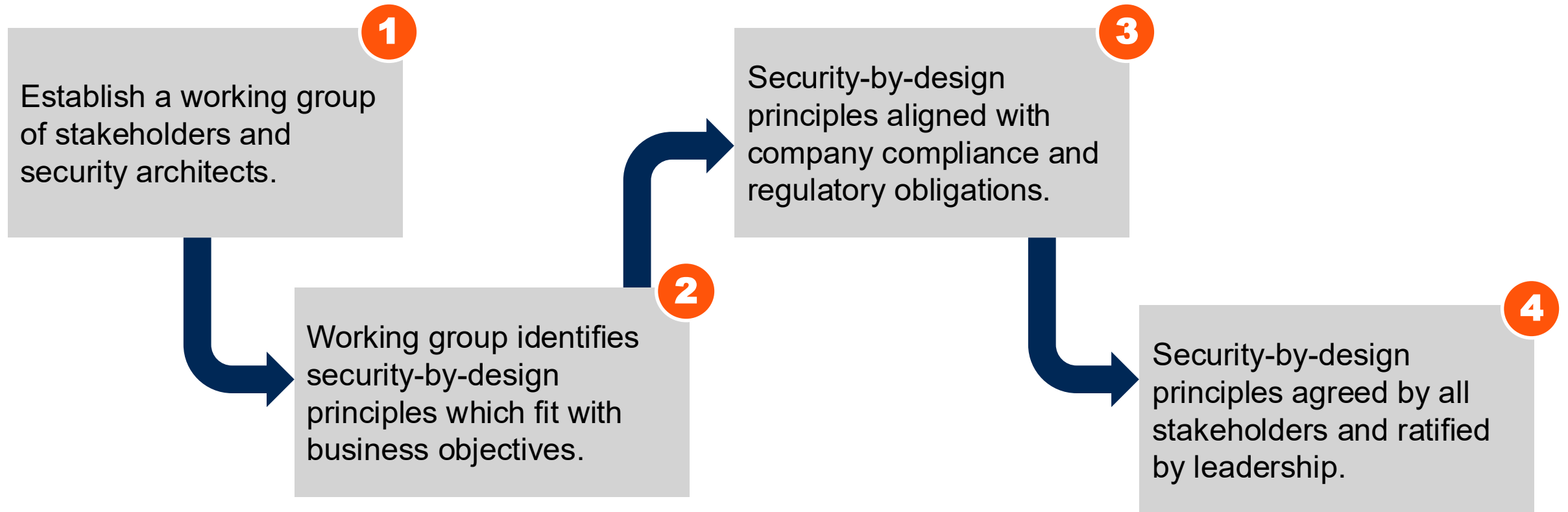
How Do You Operate Security by Design?

Define how you want security by design to operate in practice:

- Define security-by-design principles for your org.
- Create principles mapping to frameworks of security capabilities.
- Apply principles during architecting.
- Develop models and use threat modeling.



Security Architects Define Your “SbD” Principles



Establish Accountability Model

- Obtain executive sponsorship for security by design.
- Identify all stakeholders.
- Define responsibilities both within the security team and the IT organization.
- Define communication paths: for escalation, feedback and learning.

Role	Continual activities			
	Business objectives review	New business project initiation	New risks identified	Gaps/weaknesses identified
CEO	R	R	A	C
C-suite	R	R	A	C
CTO	A	A	A	C
GRC director	C	I	R	C
Enterprise architecture	—	C	C	I
(Technology design authorities)	—	I	C	I
(Technology practitioners & specialists)	—	—	I	I

Establish Security-by-Design Champions

- Each IT project needs a security-by-design champion to ensure the principles are being applied from project inception onwards.
- SbD champions work to ensure that top-level design aims are incorporated into security services.
- Champions are critical for:
 - Knowing what security-by-design-based reference security architectures are available for their project.
 - Supporting the creation of reference architecture components for reuse.



Security-by-Design Rollout

- Decide on a list of pilot candidate projects.
- Architects should:
 - Review pilot outputs — look for gaps, issues and challenges.
 - Ensure that processes and assigned resources are adequate.
 - Check for bottlenecks.
 - Gather pilot outputs into the reference architecture library.
- Rollout tuned security by design approach to all projects.

Agenda

1. Security architecture — overview.
2. What is security by design?
3. Building security by design into architecting.
- 4. Assembling and curating reference architectures.**

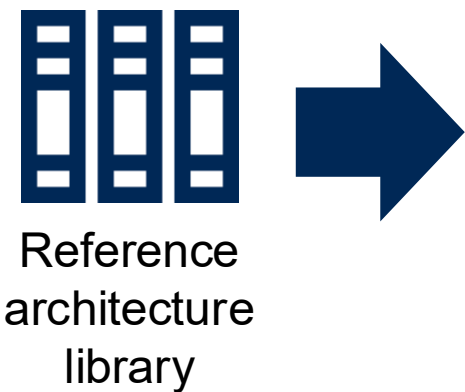


Why Use Reference Architectures?

- Defines how security vision is to be implemented.
- Creates repeatable basis.
- Helps industrialize security design.
- Provides a negotiation point between security and others.
- Provides architectural designs at the required level of resolution.

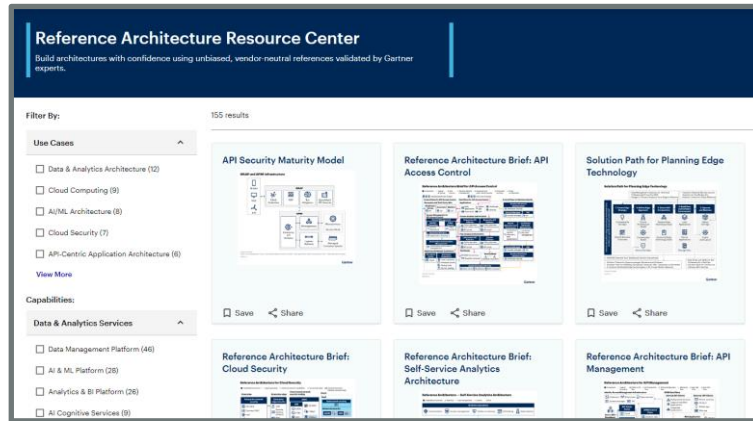
Building Reference Architectures That Have Used Security-by-Design Principles

Defining security reference architectures based on context/concept/logical architectural demands can help with assuring repeatable deployments:

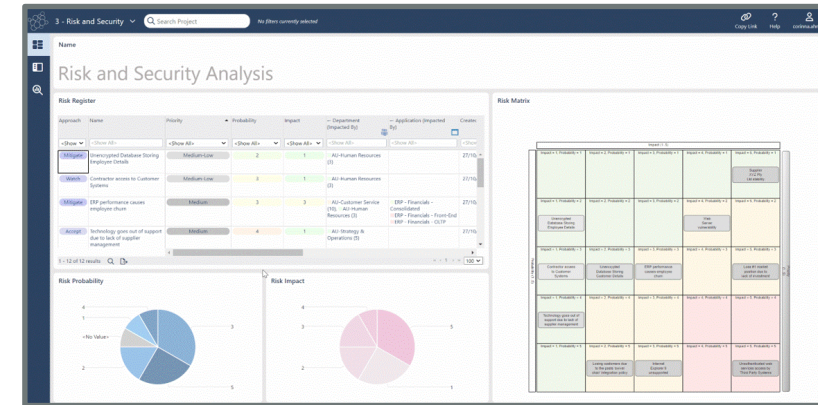


Library metadata dimensions			
Domains:	Technologies:	Capabilities:	Framework mappings:
- Enterprise - Application security - Infrastructure security - Cloud security - Data security - Network security - Identity & access	- IaaS/PaaS - SaaS - Hybrid - Orchestration platform - Hypervisor platform	- Data & analytics - Platform services - UX & UI - Applications - SW delivery & Ops - Infrastructure	- ISO 27002 - NIST CSF - CSA CCM - SOC2 - COBIT
	Actions:	Use cases:	
	Implement Modernize Address tech debt	Mobile Web app Data analytics ...	

Security Reference Architecture Curation



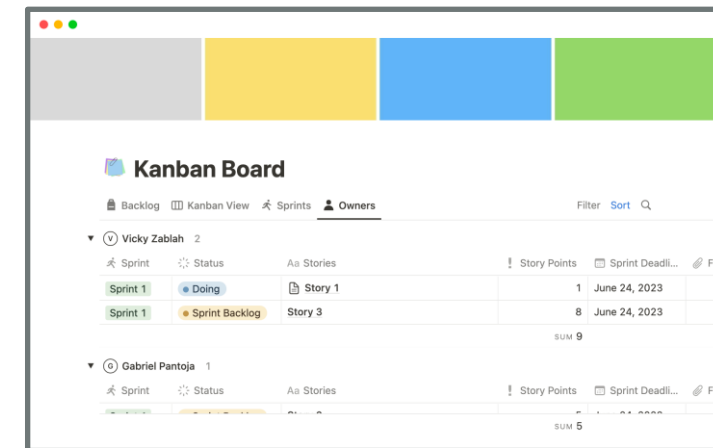
Custom tool



Enterprise architecture tool



Structured file and data store



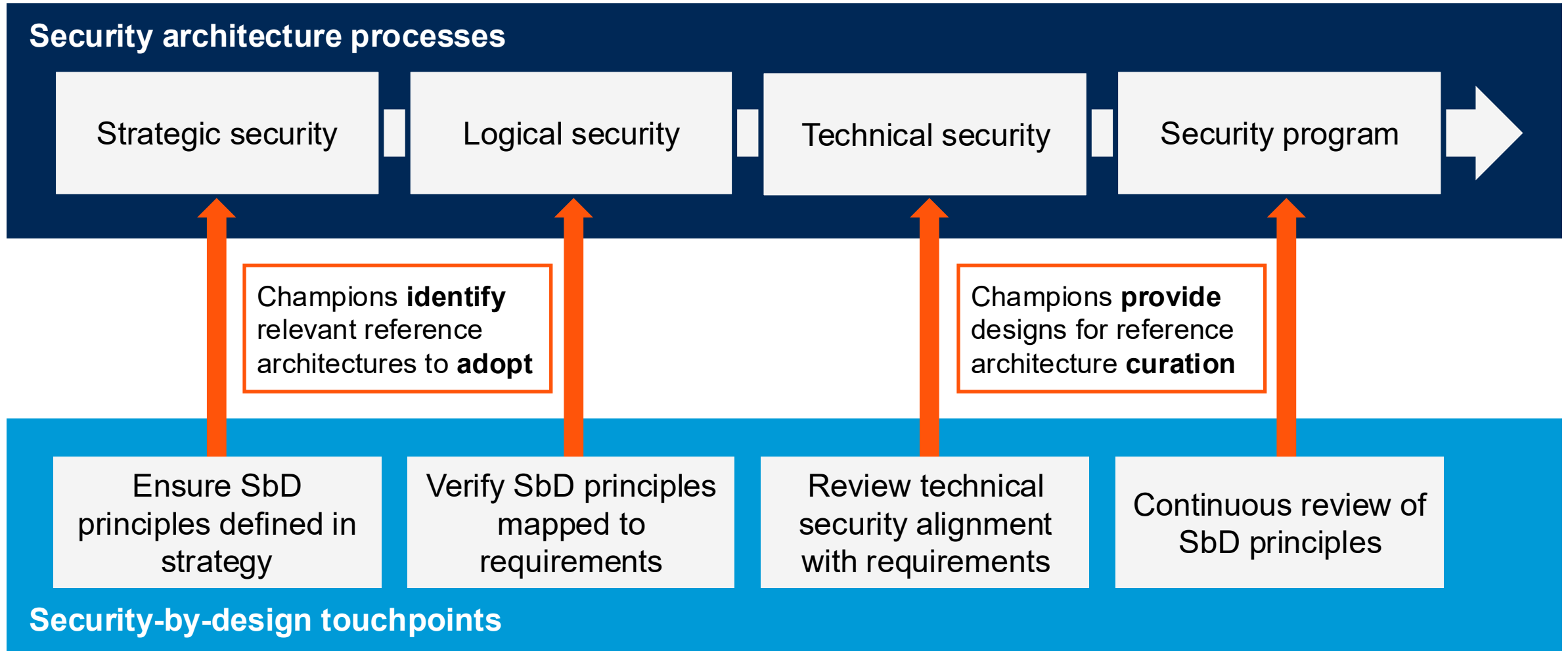
Metadata management

How Low Do You Go With Reference Architectures?

SABSA Architectural Layers



Align All Security Architecture Processes With Reference Architecture and Security by Design



Recommendations

- ④ Prioritize security-by-design principles when building out your security architecting processes.
- ④ Use security by design to bake in effective security early, reducing potential friction and rework.
- ④ Establish reference architectures for security to support consistency and help accelerate security design.

Gartner Recommended Research

To learn more about access to Gartner research, expert analyst insight, and peer communities, contact your Gartner representative or click on “Become A Client” on gartner.com to speak with one of our specialists.

- 🔍 [Use Security Architecture to Enable “Security by Design”](#)
Richard Bartley
- 🔍 [Quick Answer: 4 Key Insights to Elevate Your Security Architecture](#)
Richard Bartley
- 🔍 [Using Generative AI Chat Assistants to Enhance Security Architecture](#)
Richard Bartley
- 🔍 [Guide to Cybersecurity Concepts](#)
Patrick Hevesi and Richard Bartley
- 🔍 [Reference Architecture Resource Center](#)